**title: External Teams chats and help-desk lures: what to check in your tenant**
**date: 2026-10-28**
**summary: Recent reports describe Teams chats from outside the organisation and IT-support scams used to deliver malware. The settings and processes that reduce this risk, and what is still unclear.**
**draft: false**

## What was reported

- **Teams support scams.** The Hacker News reported on 26 Oct 2026 that threat actors used Microsoft Teams messages posing as IT support to deploy malware and ransomware, describing a recurring social-engineering pattern.
- **External chats as delivery.** Dark Reading reported on 27 Oct 2026 an ongoing campaign that used external Teams chats to deliver malware within about 15 minutes of first contact.
- **Detection is coming.** BleepingComputer reported on 23 Oct 2026 that Microsoft plans AI-powered phishing detection for Teams messages, starting in early November 2026. Check the Message Center for the exact rollout and settings.

**Confirmed (from the reports):** the scam pattern and the external-chat delivery method.
**Likely:** users who trust a chat from an unfamiliar external account are the main path in.
**Unclear:** how many tenants were affected and which Teams settings the campaign abused. Verify before stating these as facts.

## Settings to review

| Area | Question to answer | Where to look |
|---|---|---|
| External access | Which domains can start chats with your users? Is this open, allow-listed or blocked? | Teams admin center, external access |
| External users | | Teams meeting and external access policies |

| | | |
|---|---|---|
| | Can external users join meetings or chats without a prompt? | |
| Message protection | Is Defender for Office 365 covering Teams links and files? | Microsoft Defender portal, Teams protection |
| Help desk | Can a caller get a password reset or MFA change with only a name and employee ID? | Your helpdesk procedure |

Change external access only after you know which business partners depend on it. A full block can break real work.

## What I would do

1. **Decide the external access model** with the business owners. Write down the allowed domains and the reason for each.
2. **Harden the help desk.** Require a verification step that an outside caller cannot pass from public information alone, and never approve MFA changes on an unverified request.
3. **Train with the real pattern.** Show users an example of a fake support chat and what to do: do not click, do not install, report to IT.
4. **Test the reporting path.** Confirm a user can report a suspicious Teams message in a few clicks, and that someone reads it.

## Verification

- External access settings are documented and match the approved list.
- A test chat from an unlisted external domain behaves as your policy says.
- The help-desk procedure has been walked through with a tabletop scenario.

*Sources: The Hacker News (26 Oct 2026), Dark Reading (27 Oct 2026) and BleepingComputer (23 Oct 2026), as summarised on this site. Check the original reports before sharing details.*